CyberDefenders

Resolución de Laboratorio

RetailBreach

Análisis de una captura de tráfico de una tienda en línea comprometida: identificación del atacante, reconocimiento, robo de sesión de un administrador y acceso a información sensible del servidor.

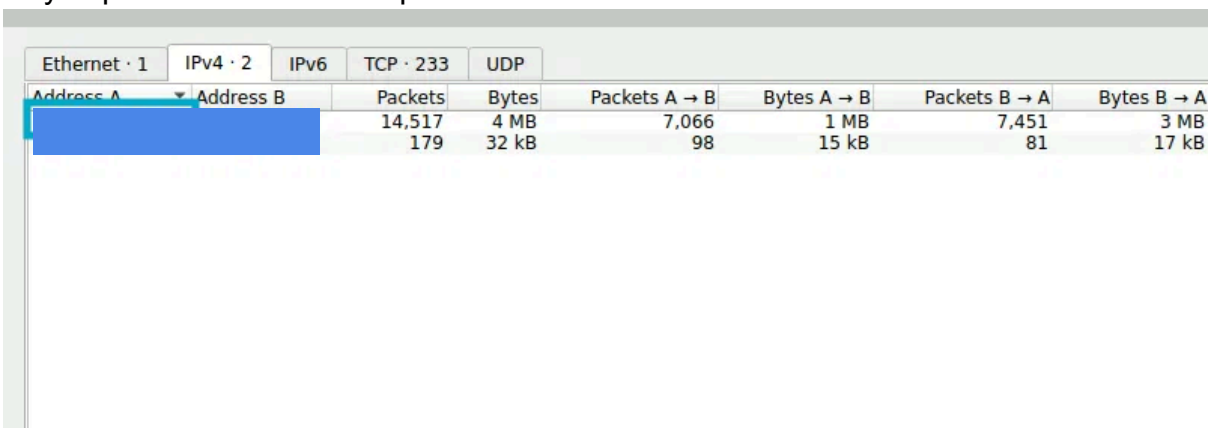
URL:
https://cyberdefenders.org/blueteam-ctf-challenges/retailbreach/

Writeup por Jenrrisinho

Noviembre 2026

Pregunta 1: Identificar la IP del atacante

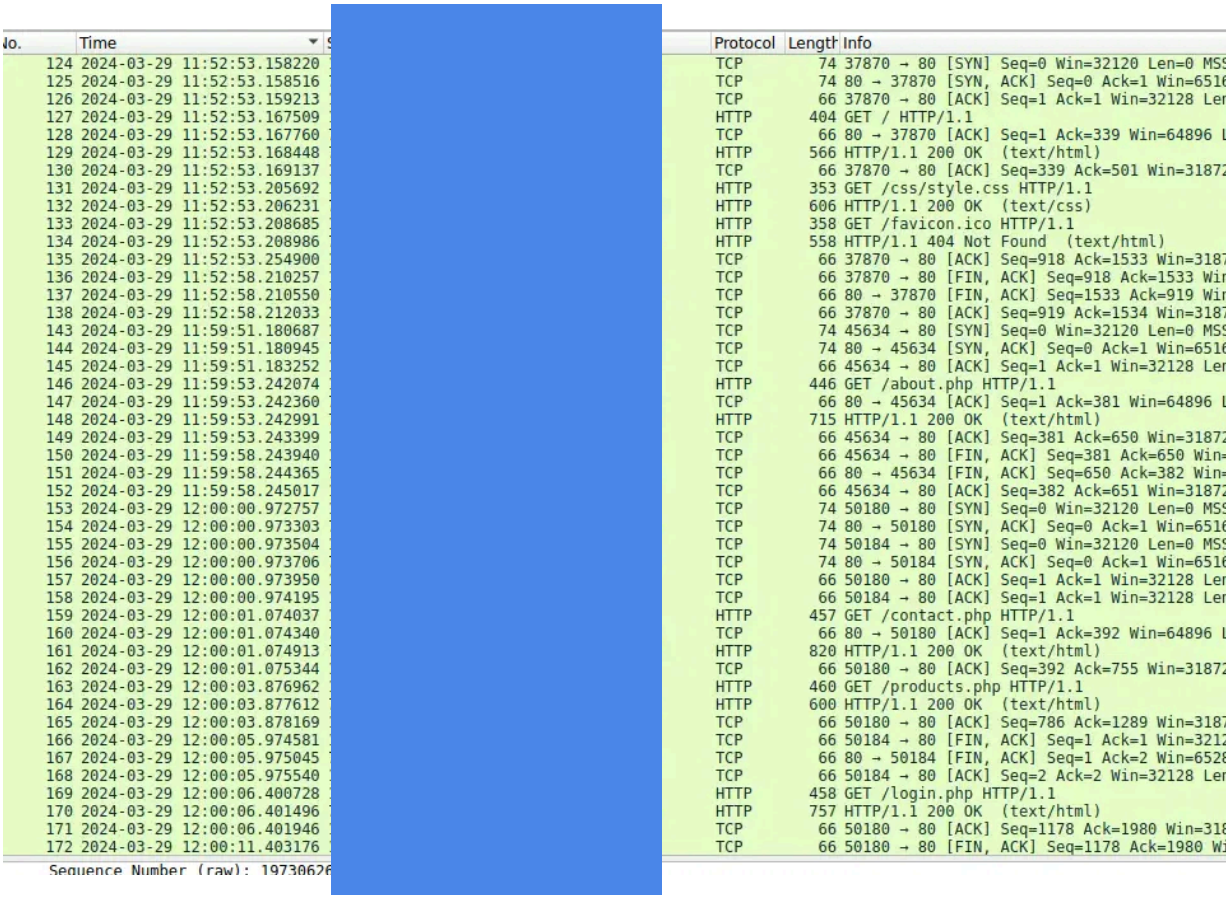
Para empezar, conviene tener una vista general del tráfico. Abre el PCAP en Wireshark y entra a *Statistics* > *Conversations*, pestaña **IPv4**. Ahí se ve qué direcciones hablan con el servidor y cuánto tráfico generan. Una IP con un volumen muy superior al resto es sospechosa.



Ethernet · 1 | IPv4 · 2 | IPv6 | TCP · 233 | UDP

Address A	Address B	Packets	Bytes	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A
[redacted]		14,517	4 MB	7,066	1 MB	7,451	3 MB
		179	32 kB	98	15 kB	81	17 kB

Para confirmarlo, filtra el tráfico con `ip.addr == <IP sospechosa>` y observa qué hace: si recorre el sitio página por página de forma ordenada, es una señal clara de reconocimiento.

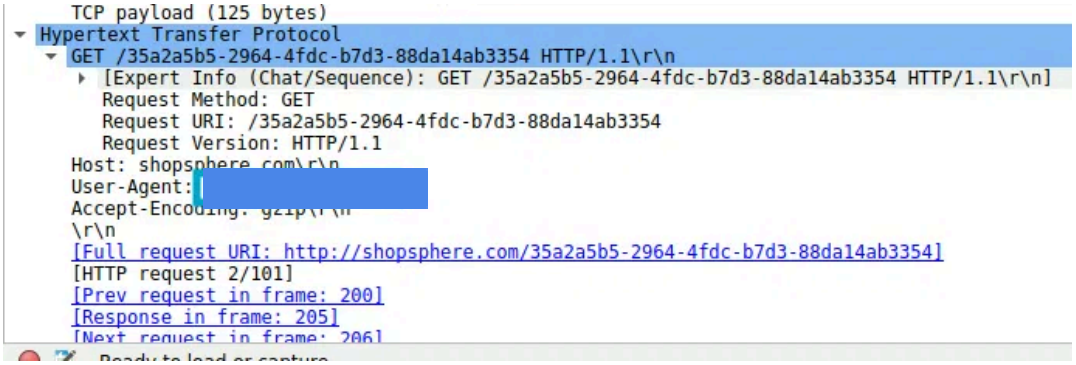


No.	Time	Protocol	Length	Info
124	2024-03-29 11:52:53.158220	TCP	74	37870 → 80 [SYN] Seq=0 Win=32120 Len=0 MSS
125	2024-03-29 11:52:53.158516	TCP	74	80 → 37870 [SYN, ACK] Seq=0 Ack=1 Win=6516
126	2024-03-29 11:52:53.159213	TCP	66	37870 → 80 [ACK] Seq=1 Ack=1 Win=32128 Len
127	2024-03-29 11:52:53.167509	HTTP	404	GET / HTTP/1.1
128	2024-03-29 11:52:53.167760	TCP	66	80 → 37870 [ACK] Seq=1 Ack=339 Win=64896 L
129	2024-03-29 11:52:53.168448	HTTP	566	HTTP/1.1 200 OK (text/html)
130	2024-03-29 11:52:53.169137	TCP	66	37870 → 80 [ACK] Seq=339 Ack=501 Win=3187
131	2024-03-29 11:52:53.205692	HTTP	353	GET /css/style.css HTTP/1.1
132	2024-03-29 11:52:53.206231	HTTP	606	HTTP/1.1 200 OK (text/css)
133	2024-03-29 11:52:53.208685	HTTP	358	GET /favicon.ico HTTP/1.1
134	2024-03-29 11:52:53.208986	HTTP	558	HTTP/1.1 404 Not Found (text/html)
135	2024-03-29 11:52:53.254900	TCP	66	37870 → 80 [ACK] Seq=918 Ack=1533 Win=3187
136	2024-03-29 11:52:58.210257	TCP	66	37870 → 80 [FIN, ACK] Seq=918 Ack=1533 Win
137	2024-03-29 11:52:58.210550	TCP	66	80 → 37870 [FIN, ACK] Seq=1533 Ack=919 Win
138	2024-03-29 11:52:58.212033	TCP	66	37870 → 80 [ACK] Seq=919 Ack=1534 Win=3187
143	2024-03-29 11:59:51.180687	TCP	74	45634 → 80 [SYN] Seq=0 Win=32120 Len=0 MSS
144	2024-03-29 11:59:51.180945	TCP	74	80 → 45634 [SYN, ACK] Seq=0 Ack=1 Win=6516
145	2024-03-29 11:59:51.183252	TCP	66	45634 → 80 [ACK] Seq=1 Ack=1 Win=32128 Len
146	2024-03-29 11:59:53.242074	HTTP	446	GET /about.php HTTP/1.1
147	2024-03-29 11:59:53.242360	TCP	66	80 → 45634 [ACK] Seq=1 Ack=381 Win=64896 L
148	2024-03-29 11:59:53.242991	HTTP	715	HTTP/1.1 200 OK (text/html)
149	2024-03-29 11:59:53.243399	TCP	66	45634 → 80 [ACK] Seq=381 Ack=650 Win=3187
150	2024-03-29 11:59:58.243940	TCP	66	45634 → 80 [FIN, ACK] Seq=381 Ack=650 Win=
151	2024-03-29 11:59:58.244365	TCP	66	80 → 45634 [FIN, ACK] Seq=650 Ack=382 Win=
152	2024-03-29 11:59:58.245017	TCP	66	45634 → 80 [ACK] Seq=382 Ack=651 Win=3187
153	2024-03-29 12:00:00.972757	TCP	74	50180 → 80 [SYN] Seq=0 Win=32120 Len=0 MSS
154	2024-03-29 12:00:00.973303	TCP	74	80 → 50180 [SYN, ACK] Seq=0 Ack=1 Win=6516
155	2024-03-29 12:00:00.973504	TCP	74	50184 → 80 [SYN] Seq=0 Win=32120 Len=0 MSS
156	2024-03-29 12:00:00.973706	TCP	74	80 → 50184 [SYN, ACK] Seq=0 Ack=1 Win=6516
157	2024-03-29 12:00:00.973950	TCP	66	50180 → 80 [ACK] Seq=1 Ack=1 Win=32128 Len
158	2024-03-29 12:00:00.974195	TCP	66	50184 → 80 [ACK] Seq=1 Ack=1 Win=32128 Len
159	2024-03-29 12:00:01.074037	HTTP	457	GET /contact.php HTTP/1.1
160	2024-03-29 12:00:01.074340	TCP	66	80 → 50180 [ACK] Seq=1 Ack=392 Win=64896 L
161	2024-03-29 12:00:01.074913	HTTP	820	HTTP/1.1 200 OK (text/html)
162	2024-03-29 12:00:01.075344	TCP	66	50180 → 80 [ACK] Seq=392 Ack=755 Win=3187
163	2024-03-29 12:00:03.876962	HTTP	460	GET /products.php HTTP/1.1
164	2024-03-29 12:00:03.877612	HTTP	600	HTTP/1.1 200 OK (text/html)
165	2024-03-29 12:00:03.878169	TCP	66	50180 → 80 [ACK] Seq=786 Ack=1289 Win=3187
166	2024-03-29 12:00:05.974581	TCP	66	50184 → 80 [FIN, ACK] Seq=1 Ack=1 Win=3212
167	2024-03-29 12:00:05.975045	TCP	66	80 → 50184 [FIN, ACK] Seq=1 Ack=2 Win=6528
168	2024-03-29 12:00:05.975540	TCP	66	50184 → 80 [ACK] Seq=2 Ack=2 Win=32128 Len
169	2024-03-29 12:00:06.400728	HTTP	458	GET /login.php HTTP/1.1
170	2024-03-29 12:00:06.401496	HTTP	757	HTTP/1.1 200 OK (text/html)
171	2024-03-29 12:00:06.401946	TCP	66	50180 → 80 [ACK] Seq=1178 Ack=1980 Win=318
172	2024-03-29 12:00:11.403176	TCP	66	50180 → 80 [FIN, ACK] Seq=1178 Ack=1980 Wi

Sequence Number (raw): 1973062[redacted]

Pregunta 2: Herramienta de fuerza bruta de directorios

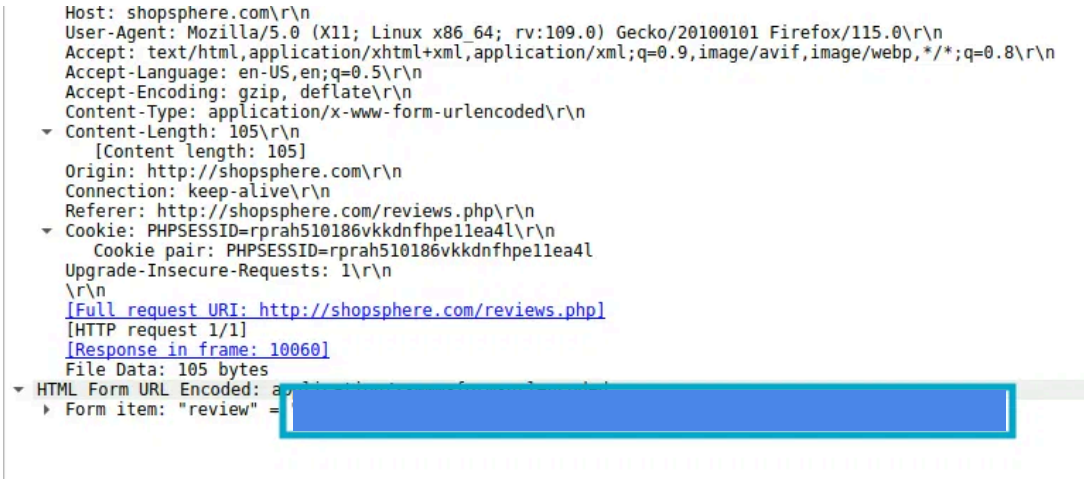
Dentro del tráfico del atacante, busca una ráfaga de peticiones HTTP seguidas a rutas que no existen en el sitio. Abre una de esas peticiones y revisa el **encabezado User-Agent** en el panel de detalles. Las herramientas automatizadas suelen identificarse ahí, y a veces incluso con su versión.



Un filtro útil para confirmarlo: `http.user_agent contains "<nombre de la herramienta>"`.

Pregunta 3: Payload XSS

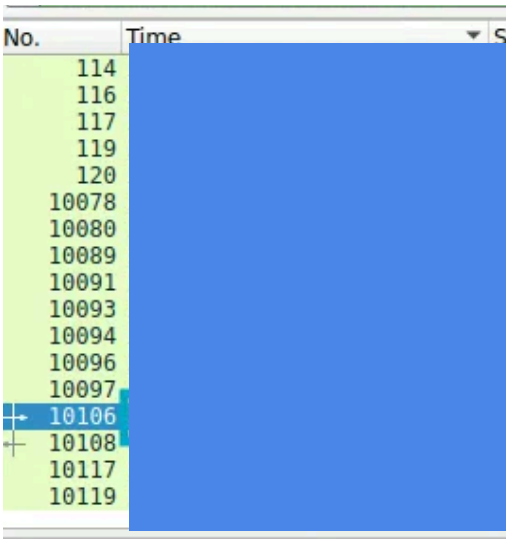
Cambia el enfoque y mira solo las peticiones que **envían datos** al sitio: `ip.addr == <IP del atacante> && http.request.method == POST`. Revisa el cuerpo de la petición, en la sección *HTML Form URL Encoded*, y fíjate en el contenido del campo que el atacante envió. Lo que verás es código pensado para ejecutarse en el navegador de otra persona.



Pregunta 4: Momento en que el administrador visita la página infectada

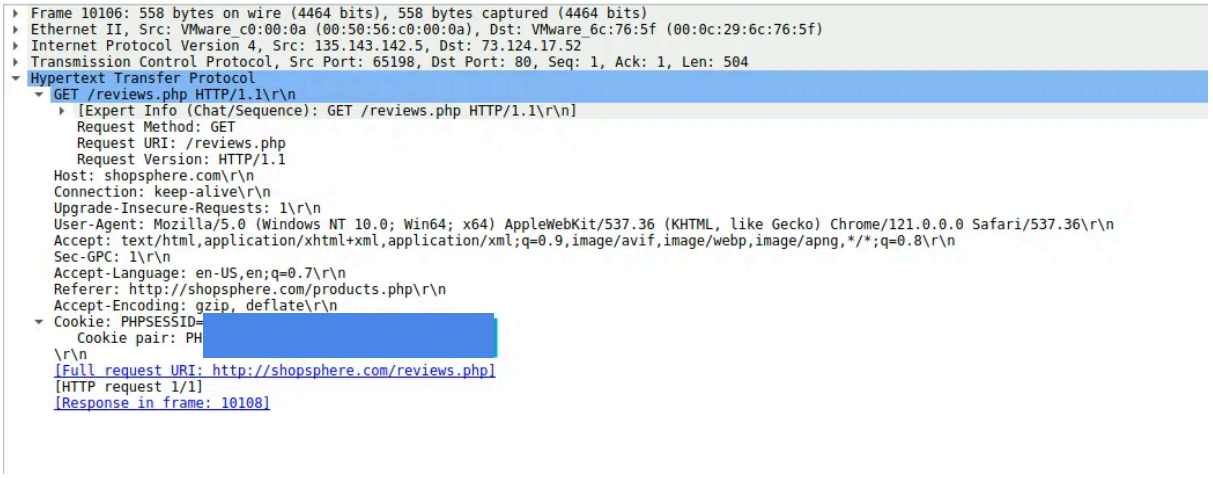
Ahora busca la actividad del **otro usuario** que apareció en las conversaciones. Filtra por su IP: `http && ip.addr == <IP del administrador>`. Reconocerás que es el administrador porque entra a rutas de administración. Busca la primera vez que carga la página donde el atacante dejó su payload y anota la marca de tiempo.

Un detalle importante: la pregunta pide **UTC**. Verifica en *View* > *Time Display Format* que Wireshark muestre UTC y no la hora local.



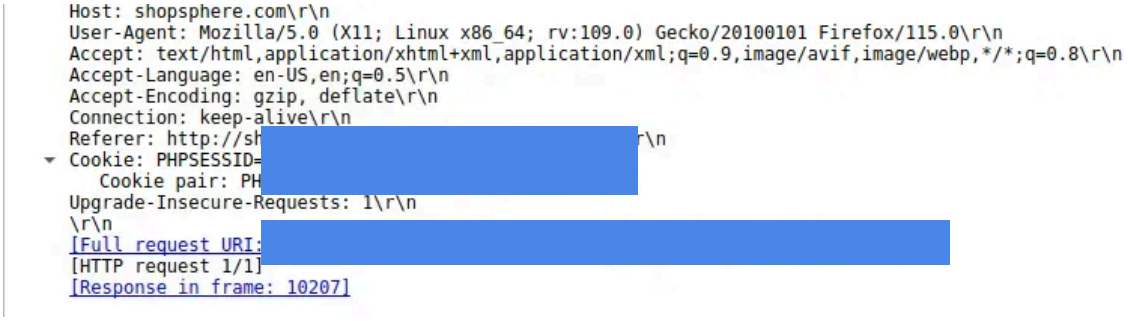
Pregunta 5: Token de sesión robado

Abre el paquete de esa visita del administrador y despliega la sección HTTP. En los encabezados, el campo **Cookie** contiene el identificador de sesión. Para comprobar que el atacante lo robó y lo usó, puedes filtrar con `http.cookie contains "<token>"` y ver si aparece en peticiones que vienen de la IP del atacante.



Pregunta 6: Script explotado

Revisa las peticiones del atacante **después** de obtener la sesión del administrador, con esa cookie ya incluida. Fíjate a qué rutas del panel de administración accede y en qué parámetros se envían valores. Uno de los scripts recibe como parámetro el nombre de un archivo, algo que merece sospecha.



Pregunta 7: Payload para acceder a un archivo sensible

Sigue la actividad del atacante contra ese mismo script. Después de probarlo con un valor normal, cambia el parámetro por una ruta que intenta **salir del directorio previsto** para llegar a un archivo del sistema. Revisa también la respuesta del servidor (haz clic derecho en el paquete, *Follow* > *HTTP Stream*) para ver si devolvió el contenido.

